

Product Requirements Document

AI-Based Phishing and Social Engineering Detection Assistant

Problem Statement: PS57 | **Theme:** Blockchain & Cybersecurity | **Event:** SIH 2026 — NIT Raipur Internal Selection

1. Problem Statement

Non-technical users (students, enterprise staff, senior citizens) fall victim to phishing and social engineering not because they lack awareness of malware, but because modern attacks exploit **psychological manipulation** rather than technical exploits. Existing tools (VirusTotal, spam filters, browser blocklists) only flag **known-bad URLs or signatures** — they give a binary "safe/unsafe" verdict with no human-readable explanation, and they are reactive: a brand-new (zero-day) phishing domain or a link-free social engineering email slips through undetected.

Target users: College students, enterprise staff, senior citizens.

Core gap: No accessible tool explains *why* a message is dangerous in plain language, or catches attacks that don't rely on a known-malicious link at all.

2. Proposed Solution

A dual-layer defense system:

1. **Local deterministic heuristics** — fast, explainable, no API dependency. Domain lookalike detection (Levenshtein distance), anchor-tag/display-text mismatch detection, TLD risk scoring, urgency/fear keyword detection.
2. **LLM reasoning engine** — analyzes intent and psychological pressure tactics (urgency, authority impersonation, fear) that pure pattern-matching can't catch, and produces a plain-language explanation.

The two layers are combined into a **weighted risk score** (e.g., $0.4 \times \text{Heuristic} + 0.6 \times \text{AI}$) that outputs a 0–100 threat rating, plus a human-readable breakdown of *why* — not just *that* — a message is dangerous.

Core innovation / differentiator: Proactive and explainable, vs. existing tools which are reactive and opaque. Catches zero-day phishing content that exists on no blocklist yet, because detection is based on pattern and intent, not a database lookup.

3. Goals & Success Metrics

Goal	Metric
Reduce manual triage time	From minutes of manual checking → under 3 seconds per message
Catch novel/zero-day attacks	Correctly flag attacks with no known-bad link (Case 2 scenario)
Avoid false positives	Zero false flags on legitimate messages (Case 3 scenario)
Explainability	Every verdict includes a plain-language reason, not just a score

4. Non-Goals (Round 1 / Phase 2 scope)

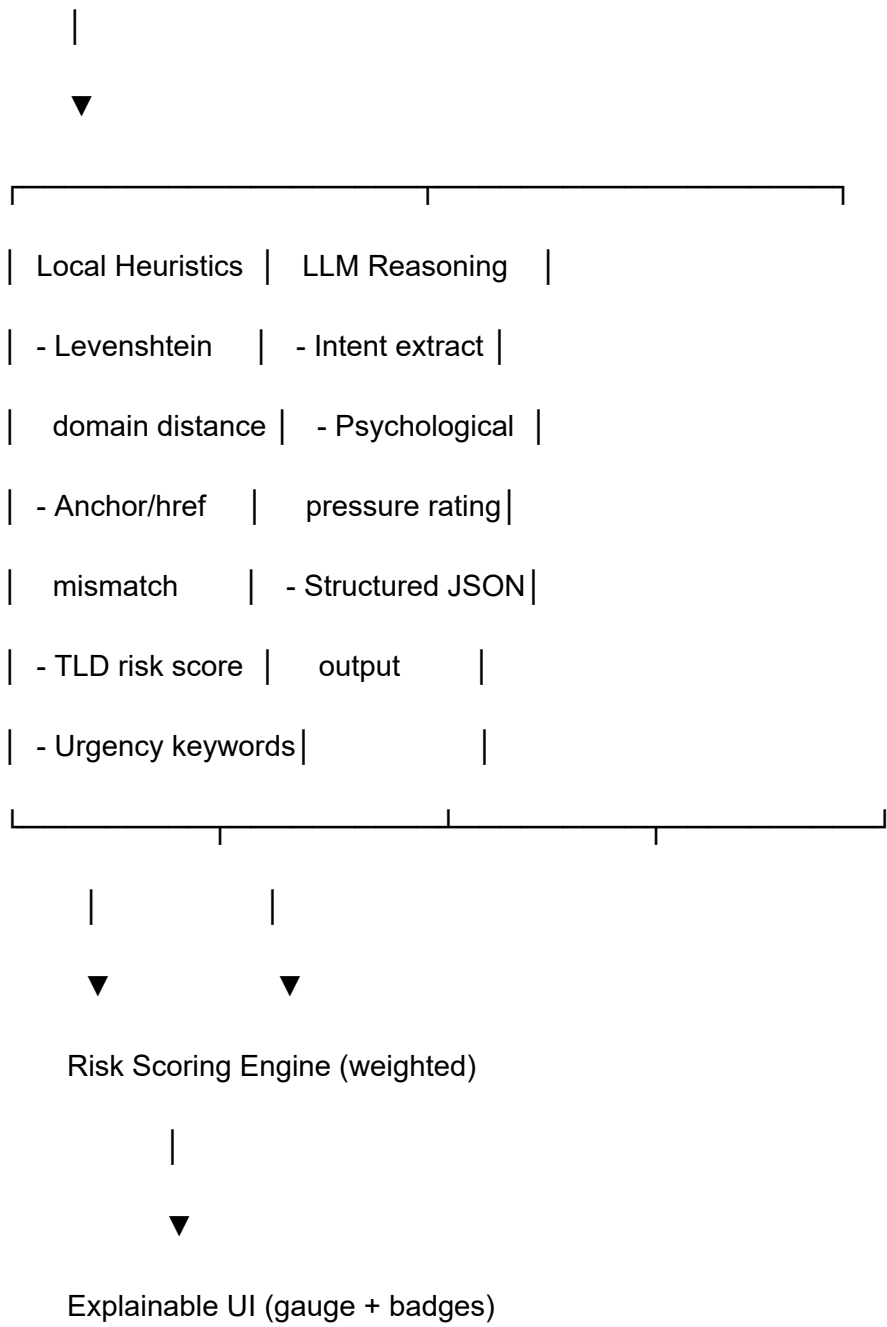
- No production deployment or real inbox integration in this phase.
 - No mobile app — web dashboard only for the demo.
 - No handling of attachments/malware scanning — text and link analysis only.
 - No multi-language support in the first build (English-only test cases).
-

5. User Flow

1. User pastes raw text, SMS content, or a URL into the input box.
2. System runs local heuristic checks (domain distance, anchor mismatch, TLD score, keyword scan).
3. System sends the content to the LLM with a structured system prompt requesting JSON output (risk score, verdict, threat factors, explanation).
4. Risk Scoring Engine combines both signals into a final 0–100 score.
5. UI displays a threat gauge, verdict badge, and plain-language explanation.

6. Technical Architecture

Input (text / SMS / URL)



6.1 Local Heuristics Module

- **Domain lookalike detection:** Levenshtein (edit-distance) comparison against a maintained list of protected/commonly-impersonated brand domains. Normalized distance threshold flags close matches (e.g., `sbi-kyc-update.top` vs `sbi.co.in`).
- **Anchor/href mismatch:** Parses `<a>` tag display text vs actual `href` target; flags mismatches.
- **TLD risk scoring:** Static risk weights for commonly-abused TLDs (`.top`, `.xyz`, etc.).
- **Keyword/urgency detection:** Regex/keyword bank for fear and urgency language ("immediate action required," "account suspended in 24h").

6.2 LLM Reasoning Module

- Single Node.js API route.
- Strict system prompt enforcing JSON-only structured output:

```
{  
  
  "risk_score": 85,  
  
  "verdict": "Phishing",  
  
  "threat_factors": ["High Urgency", "Impersonation of Bank", "Mismatched Domain"],  
  
  "explanation": "This message pretends to be from State Bank, but links to an unverified  
third-party domain."  
  
}
```

- PII is stripped/anonymized from the payload before it is sent to the LLM API.

6.3 Risk Scoring Engine

- Combines heuristic score and LLM score via a weighted formula (baseline: $0.4 \times \text{Heuristic} + 0.6 \times \text{AI}$, tunable).
- Outputs final 0–100 threat rating.

6.4 Frontend / UI

- Single-page dashboard: paste area, 0–100 gauge bar, threat-factor badges, plain-language explanation panel.
- Pre-loaded sample buttons for the 3 test cases, so the live demo doesn't depend on network/API reliability.

7. Tech Stack

Layer	Choice
Frontend + Backend	Next.js / Node.js
AI Reasoning	Gemini or Claude API, structured JSON output
Deterministic Logic	Custom JavaScript (regex, URL parsing, Levenshtein)

8. Test Cases (for demo & validation)

Case	Description	Expected Verdict
Case 1	Fake bank KYC update, urgency keywords, misspelled link (sbi-kyc-update.top)	High-risk phishing
Case 2	Polite "HR performance review" email, no links, asks for credentials/attachment	High-risk social engineering (tests LLM layer, since no link exists to flag)
Case 3	Real college notification or receipt	Legitimate — zero false positive

9. Privacy & Security Considerations

- PII anonymized before any payload is sent to the LLM API.
- No storage of user-submitted message content beyond the session (Phase 1 scope).
- Local heuristics run first so obviously benign content doesn't need to leave the system unnecessarily.

10. Roadmap

Round 1 (PPT only) — due Aug 22

- No code required. Deliverable is the 5-slide idea presentation.

Phase 2 (if shortlisted) — Aug 25–29 | Day | Milestone | |---|---| | Aug 25–26 | Heuristic rule engine + LLM API pipeline | | Aug 27–28 | UI dashboard + risk gauge | | Aug 29 | Live demo testing against 3 benchmark cases | | Final | Pitch practice — 60-second live demonstration |

11. Future Scope (post-hackathon)

- Lightweight Chrome extension for real-time parsing inside Gmail/Outlook web.
- Homoglyph/Unicode confusable detection (catches visually-identical characters, e.g., Cyrillic "o" vs Latin "o" — a gap plain Levenshtein distance doesn't cover).
- Multi-language support.
- Attachment/malware scanning layer.

12. Open Risks / Known Limitations

- Levenshtein-based domain detection alone won't catch homoglyph attacks (different character sets that render identically) — flagged as future scope, not solved in this build.
- LLM-based scoring introduces API latency/cost and reliability dependency — mitigated in the demo via hardcoded fallback cases.
- False positives are possible on legitimate messages that coincidentally resemble flagged patterns — this is why heuristics and LLM signals are weighted, not treated as independent binary flags.